

CASE STUDY / JUNE 2026

Independent Web Application VAPT Assessment

A sanitized evidence brief documenting the methodology, validated risk, and remediation output from an authorized CRM security challenge. Client identifiers, infrastructure details, customer data, exploit payloads, and screenshots have been intentionally omitted.

09

VALIDATED FINDINGS

04

CRITICAL SEVERITY

05

HIGH SEVERITY

Scope and method

A multi-tenant CRM was tested through black-box assessment and JavaScript source review. Coverage included authentication, authorization, tenant isolation, input validation, API exposure, and information disclosure. Workflow: Map - Validate - Exploit - Report - Retest.

Finding themes

THEME_01 Broken access control Privilege escalation and cross-tenant object access.	THEME_02 Authentication and API gaps Sensitive routes lacked consistent server-side enforcement.
THEME_03 Stored cross-site scripting Persistent input was rendered without safe output encoding.	THEME_04 Information disclosure A debug surface revealed internal security configuration.

Security value delivered

REPRODUCIBLE Manual validation with clear steps and impact.	ACTIONABLE Prioritized remediation tied to each root cause.	RETESTABLE A practical verification plan for corrected controls.
---	---	--

PUBLIC-SAFE DISCLOSURE

The source report remains private because it is classified confidential and contains engagement-specific infrastructure, customer data, and proof-of-concept material. This brief demonstrates the work without exposing sensitive data.

Prepared by Ramkumar M

VAPT Engineer | Web, API, Mobile Application and Network Security | raamk575@gmail.com